

• SOWKNOW Codebase Audit Report

Principal Security & Performance Architecture Review
Scope: frontend/, backend/app/, scripts/, nginx/, Docker compose files
Date: 2026-07-13
Method: Ground-up source analysis; no reliance on prior audit documents.

Executive Dashboard

Metric	Value
Overall Health Score	52 / 100 (Moderate–Poor; production-deployable only with immediate security patches)
Critical Issues	6
High Issues	28
Medium Issues	~36
Low Issues	~20
Performance Bottlenecks	27 verified

Duplicate-Logic Instances ~170 verified across 21 clusters	
Time-to-Fix Estimate 3-week sprint (2 engineers) + 1 week soak/stabilization	

Health Score Justification

- Security (40% weight): 55/100 — Cookie-based JWT is mostly correct, but critical secrets exposure, default admin password, direct backend exposure, and broken rate-limiting behind nginx drop the score sharply.
- Performance (25% weight): 48/100 — Chat streaming, knowledge-graph simulation, dashboard burst polling, and un-debounced searches create predictable main-thread and backend load issues.
- Code Quality / Architecture (20% weight): 45/100 — Massive duplication (LLM providers, Redis clients, permission checks, fetch wrappers) and competing HTTP/state abstractions.
- Error Handling / UX Resilience (15% weight): 35/100 — No global Error Boundary, systematic console.error-only catches, no request cancellation on most pages.

Top 5 Blockers to Production Safety

1. JWT_SECRET is passed into the frontend Docker build (image-layer leak).
2. scripts/deploy.sh falls back to Admin123! for the admin account.
3. Backend is exposed directly on host port 8001, bypassing nginx.
4. No global React/Next.js Error Boundary anywhere in frontend/.
5. Rate-limiting uses request.client.host, making per-client limits ineffective behind nginx.

Security Vulnerability Log

Prioritized by risk. Only issues located in actual code are listed.

Critical

#	File	Line(s) / Function	Description	Exploit Risk
SEC-01	frontend/Dockerfile	6–9	JWT_SECRET passed as ARG/ENV into the Next.js Secret is baked into image layers; anyone can forge/verify JWTs	with image access and impersonate any user.
SEC-02	scripts/deploy.sh	225–227	ADMIN_PASSWORD="\${ADMIN_PASSWORD:-Admin123!}" admin@sowknow.local / creates admin with well-known default if env var Admin123! immediately after deployment. is missing.	Attacker logs in as

High

#	File	Line(s) / Function	Description	Exploit Risk
---	------	--------------------	-------------	--------------

#	File	Line(s) / Function	Description	Exploit Risk
SEC-03	scripts/init-db.sql	23–33	Inserts admin@sowknow.local row whose If hash is ever valid, persistent inline comment documents hash of admin backdoor; leaks intended Admin123!. privileged identity.	
SEC-04	docker-compose.yml / docker-compose.production.yml	197–198 / 125–126	Backend mapped to host port 8001, Bypasses nginx HTTPS/HSTS/rate-limits; allowing direct access. attacker can hit backend over plain HTTP.	
SEC-05	backend/app/limiter.py	12–32	Limiter(key_func=get_remote_address) uses Behind nginx, all clients share one immediate TCP peer. rate-limit bucket; single attacker can exhaust it and DoS legitimate users.	
SEC-06	backend/app/api/auth.py	82–86, 870–877	Telegram auth skips Telegram-side getChat Anyone with BOT_API_KEY can create verification when TELEGRAM_BOT_TOKEN is arbitrary admin users without owning a Telegram account. unset.	

	SEC-07	backend/app/api/auth.py	423–424	Login checks is_active but never	
		Attacker registering with someone		email_verified.	else's email can
		authenticate before			the real owner verifies.

	SEC-08	backend/app/api/auth.py	359–364	Registration returns "User with this	
		Attacker builds a list of valid emails		email already exists", enabling email	for
		credential stuffing / phishing.		enumeration.	

Medium

	#	File	Line(s) /	Description	Exploit Risk
			Function		
	SEC-09	backend/app/api/auth.py	386	No account-level lockout or	
		Distributed credential stuffing can		progressive delay after failed	continue
		indefinitely against a target			

			logins.	account.
SEC-10	backend/app/api/auth.py /	213–223 / 50–52	CSRF cookie is httponly=False XSS vector can read csrf_token and backend/app/middleware/csrf.py and generated once per refresh submit authenticated write requests. cycle.	
SEC-11	backend/app/api/deps.py /	30, 53–58 /	Backend accepts JWT from Header tokens are more likely to be backend/app/api/auth.py 265–272 httpOnly cookie or logged by proxies/servers/extensions; Authorization: Bearer header. weakens cookie-only model.	
SEC-12	backend/app/services/token_blacklist.	34–56 / 127–133	Blacklist returns False when Stolen token remains usable after logout py / backend/app/api/auth.py Redis is down; logout/rotation until Redis recovers. revocation not enforced.	
SEC-13	backend/app/api/auth.py /	login/register	No MFA/2FA (TOTP, WebAuthn, Single leaked password grants full frontend/app/[locale]/login/page.tsx flows email OTP) implemented. account access; no barrier for privileged accounts.	

	SEC-14	backend/app/main.py	365–391	Dev-mode CORS/host defaults	
		Misconfigured prod instance allows		(localhost, *) are permissive	authenticated
		cross-origin requests and		if accidentally deployed as	Host-header
		injection.		production.	

Low

	#	File	Line(s) /	Description	Exploit Risk
			Function		
	SEC-15	backend/app/api/auth.py	185–210	Auth cookies lack __Host- prefix;	
	Domain	Broad COOKIE_DOMAIN lets compromised		controlled by COOKIE_DOMAIN.	
		subdomains receive auth cookies.			
	SEC-16	frontend/middleware.ts	46–48, 63–79	Route guard only checks cookie presence,	
		Dummy access_token cookie bypasses		not token validity.	client-side redirect;
		page shell may			leak.

| SEC-17 | frontend/lib/store.ts | 30–136 | Zustand persist stores |
Local attacker/extension can tamper |
| | | user/role/confidential flag in | with role to
reveal confidential UI | |
| | | localStorage. | elements.
|

| SEC-18 | nginx/nginx-http-only.conf | entire file | HTTP-only config; no HTTPS redirect
or | Accidental production use sends |
| | | HSTS. | credentials
unencrypted. |

| SEC-19 | backend/app/api/auth.py | 863 | X-Bot-API-Key compared with !=
instead of | Timing side-channel against shared bot |
| | | hmac.compare_digest(). | secret.
|

| SEC-20 | backend/app/api/auth.py | 952–961 | Telegram auth returns JWT
access_token in | Response logging/interception exposes |
| | | response body for bot client. | bearer token.
|

| SEC-21 | backend/app/schemas/admin.py | 123–136 | Admin-created users only
require 8-char | Admins can create weak-password |
| | | passwords; self-registration requires | accounts.
| | | complexity. |
|

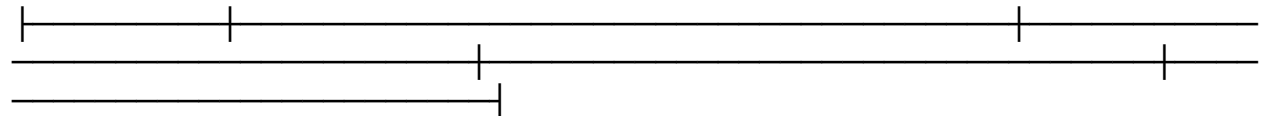
Timeline diagram showing the progression of a security audit from 2022 to 2023. Key events include:

- SEC-22 backend/app/api/auth.py (577-608) - Logout endpoint is not rate-limited despite Logout spam possible if nginx is comment claiming 60/min. (bypassed).

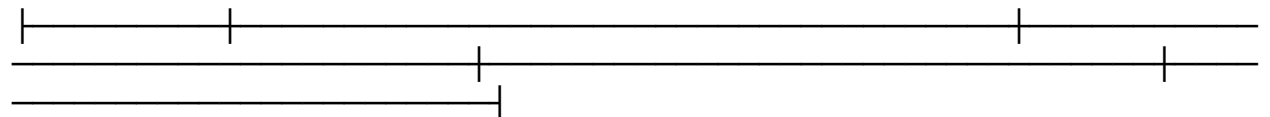
Performance Heatmap

#	Component / Endpoint	Current Behavior	Observed
Over-fetch /	Proposed Optimization	Re-render	
PERF-01 frontend/app/[locale]/chat/page.tsx	components={{ ... }} object	New	
object identity causes	Define components map		
426–461	created inline inside	ReactMarkdown + rehype	
plugins once outside component or	messages.map for every	to remount entire message	
memoize with useMemo.	assistant message.	tree.	

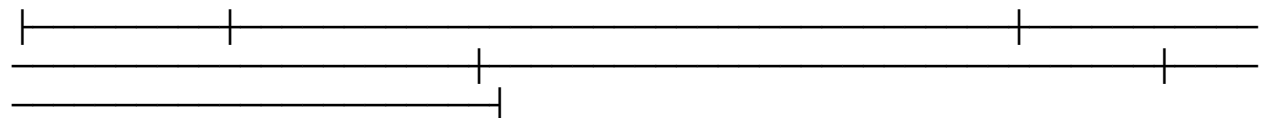
| PERF-02 | frontend/app/[locale]/chat/page.tsx | Every SSE chunk reruns |
Main-thread jank grows | Virtualize list; wrap |
| 411–545 | messages.map, re-rendering full | linearly with
message length. | messages in React.memo; |
| | message history. | | debounce
streaming | | | updates.



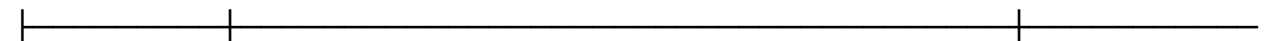
| PERF-03 | frontend/app/[locale]/chat/page.tsx | Loads up to 100 messages with | Large
histories cause DOM | Implement cursor/offset |
| 57–65, 92–105 | no pagination UI. | bloat and expensive
| pagination or | |
| | | ReactMarkdown work. |
react-window. |



| PERF-04 | backend/app/api/chat.py 245–277 → | ChatMessageResponse.sources |
UI uses only document_id, | Add lightweight |
| frontend/app/[locale]/chat/page.tsx | includes full chunk_text. | document_name,
| message-list DTO omitting |
| 470–491 | | relevance_score; large unused |
chunk_text and token | | payload. | fields.



| PERF-05 | frontend/app/[locale]/notes/page.ts | searchQuery is a useEffect | Typing a
10-char word spawns | Add useDebounce hook |
| x 63–82, 295; | dependency; every keystroke | ~10 requests.
| (300–400 ms). |
| frontend/app/[locale]/tasks/page.ts | fires a request. |
| | x 92–110, 374 | |



PERF-06	frontend/app/[locale]/search/page.t	searchGlobal and searchStream
Duplicate backend work and	Use single unified	
ranking/embedding	both run for the same query.	cost.
only when	searchGlobal	needed.

PERF-07	frontend/app/[locale]/search/page.t	typeLabels, typeCounts,
Unnecessary child re-renders	Memoize derived data with	
state	filteredGlobalResults, inline	during streaming
callbacks with	updates.	

PERF-08	frontend/app/[locale]/search/page.t	Synthesis text parsed with	CPU cost
grows with synthesis	Memoize parsed result		
frequency.	global regex into ReactNode	length and update	

PERF-09	frontend/app/[locale]/documents/pag	Three overlapping polling	
Persistent background request	Combine health checks or		
when idle.	intervals (5 s, 10 s, 15 s).	traffic even	

PERF-10	frontend/app/[locale]/documents/pag	Polling useEffect depends on	Each
		Use a ref for "has	
	e.tsx 141–152	[documents, refreshDocuments].	interval every 5 s.
	processing documents"		
			flag instead of
full			array.

PERF-11	backend/app/schemas/document.py	DocumentResponse returns	List
UI uses < 50% of returned	Add		
	58–87 →	file_path, language,	fields.
DocumentSummaryResponse			
	frontend/app/[locale]/documents/pag	ocr_processed,	
for list/search			
	e.tsx 16–27	embedding_generated, etc.	
endpoints.			

PERF-12	frontend/app/[locale]/documents/pag	Large inline style={{	New object
identity triggers	Use Tailwind classes		
	e.tsx 564–623	backgroundColor, borderColor,	subtree re-render.
(bg-green-500/10, etc.)			
		color }}	rebuilt every render.
			or
memoize style.			

PERF-13	backend/app/schemas/note.py 29–37 →	List returns full content and	Card
shows only line-clamp-3	Provide list DTO with		
	frontend/app/[locale]/notes/page.ts	user_id.	preview.
truncated			
	x 22–30		
content_preview.			

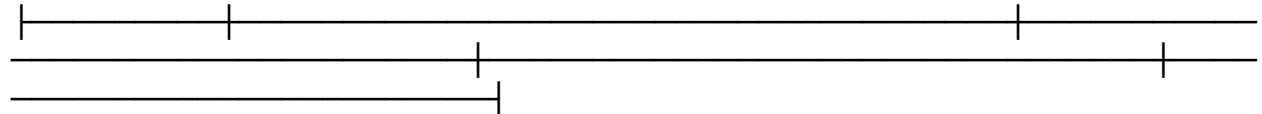
| PERF-14 | backend/app/schemas/task.py 52–66 → | TaskResponse includes notes and |
Task card does not display | Use task-summary schema |
| frontend/app/[locale]/tasks/page.ts | user_id. | notes.
| for list/search. |
| x 22–36 |

| PERF-15 | frontend/app/[locale]/dashboard/pag | loadSlowStats + loadLiveStats | Heavy
initial burst and | Stagger requests, pause |
| e.tsx 130–216, 315–328 | call 8+ endpoints on mount plus | repeated
background load. | when tab hidden, use |
| 10 s / 60 s intervals. | combined
dashboard | endpoint.
|

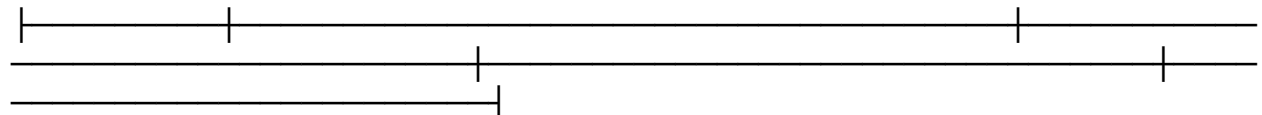
| PERF-16 | frontend/app/[locale]/dashboard/pag | Inline chart data arrays / | Recharts
re-renders all | Memoize chart data and |
| e.tsx 473–489, 526–531 | <Cell> arrays constructed on | elements even
when data | children with useMemo. |
| every render. | unchanged. |

| PERF-17 | frontend/app/[locale]/dashboard/pag | useEffect with // | Locale
change does not rerun | Include locale in |
| e.tsx 315–328 | eslint-disable-next-line | effect; stale translations.
| dependency array or use |
| react-hooks/exhaustive-deps. |
stable translation refs. |

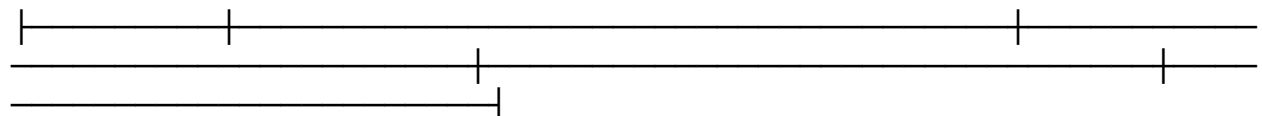
PERF-18	frontend/components/knowledge-graph	setInterval(..., 16) runs $O(n^2)$	Frame drops grow with node	Run in Web Worker or
	/GraphVisualization.tsx 133–201	repulsion loop and	count; SVG re-renders at 60	requestAnimationFrame
		setSimulatedNodes every frame.	FPS.	
with batched updates;				
		memoize SVG nodes.		



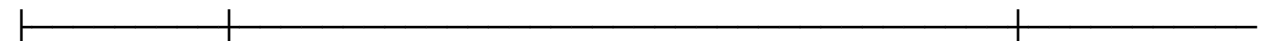
| PERF-19 | frontend/app/[locale]/knowledge-gra | EntityList rendered in sidebar | Duplicate | Hoist entity list state |
 | | ph/page.tsx 171–175, 232–236; | and list view, each fetching |
 /v1/knowledge-graph/entities | to page or use shared |
 | | frontend/components/knowledge-graph | own data. | requests. |
 | cache/store. |
 | | /EntityList.tsx 61–63 |



PERF-20	frontend/components/knowledge-graph	handleSearch updates state	Rapid keystrokes produce	Add debounced search
	/EntityList.tsx 61–63, 83–86	immediately; useEffect fetches	overlapping requests.	hook.
		on every keystroke.		



| PERF-21 | frontend/hooks/useTaskAlarms.ts | Global hook calls | Full TaskResponse returned; | Add lightweight |
 | | 20–64 | api.getTasks(1, 100) every 30 s | only alarm fields used. |
 | /v1/tasks/alarms |
 | | | on every authenticated page. |
 endpoint; pause when tab |
 | | | hidden. |



PERF-22	frontend/components/DatePicker.	useEffect calls onChange(iso)	Stale
closures; unwanted	Use callback ref or		
tsx 67–73	but excludes onChange and value	notifications on	
parent	include deps and guard		
	from deps.	re-renders.	against
loop.			

PERF-23	frontend/app/[locale]/page.tsx	mainServices and quick-actions	Extra allocations and
	Move static arrays		
	35–132, 217–245	arrays rebuilt each render;	potential re-renders.
	outside component;		
		inline styles.	
styles			replace inline
			with Tailwind.

PERF-24	frontend/app/layout.tsx 42-46	Inline style={{ margin: 0,	Slight render
overhead; harder	Move to globals.css on		
		padding: 0, fontFamily: ... }}	to override.
body.			
		on <body>.	

PERF-25	frontend/app/[locale]/layout.tsx 76	Inline style={{ minHeight:	New object
identity each	Use Tailwind arbitrary		
	'calc(100dvh - 3.5rem)' }}	render.	value
class.			

PERF-26	frontend/components/SearchModal.tsx	quickLinks array containing JSX
Unnecessary allocation; icons	Move array outside	

	144–170	constructed on every render.	recreated.
component or memoize.			
PERF-27	frontend/app/[locale]/documents/pag	Progress bars get new inline	
Frequent re-renders of	Use CSS variable or		
e.tsx 777–782	style={{ width: ... }}	on every	file-queue list during
Tailwind width class from			
	update.	uploads.	data
attribute.			

The "Copy-Paste" Index

Total verified duplicate instances: ~170 across 21 clusters.

By Feature Domain

Domain	Clusters	Verified Duplicate	Primary Files
	Instances		
Frontend UI Helpers	8	~60	frontend/app/[locale]/*,
frontend/components/*			

Frontend Data Fetching		2	~18	frontend/lib/api.ts, page files using raw fetch
Backend LLM Services		6	~28	
backend/app/services/openrouter_service.py, together_service.py,				
kimi_service.py, minimax_service.py				
Backend Redis / Cache		3	~24	14+ files with lazy Redis singleton;
3+ cache metric blocks				
Backend Permissions /		2	~40	10+ permission checks; 30+
datetime.utcnow() call sites				
Timestamps				

Detailed Clusters

#		Category		Files (sample)		Count									
Proposed Shared Location															

CP-01	Date formatting	bookmarks/page.tsx:190, collections/[id]/page.tsx:306,	
16+ calls in	frontend/lib/formatDate.ts		
		collections/page.tsx:322, search/page.tsx:315,	11 files
(already exists; migrate			
callers)		spaces/page.tsx:140, notes/[id]/page.tsx:232,234,	
		notes/page.tsx:255, tasks/[id]/page.tsx:214,230,252,	
		tasks/page.tsx:319,333, chat/page.tsx:109,	
		subscriptions/page.tsx:72-77	

CP-02	File-size formatter	documents/page.tsx:77-81,	3
instances	frontend/lib/formatFileSize.ts		
		documents/[id]/page.tsx:279-283,	
		__tests__/documents-upload.test.tsx:163-167	

CP-03	API base URL constant	lib/api.ts:9, hooks/useTagSuggestions.ts:5,	
15+ declarations	frontend/lib/env.ts		
		hooks/useSmartFolderStream.ts:46, login/page.tsx:32,	
		register/page.tsx:32,	in 12+ files
		verify-email/[token]/page.tsx:32,71,229,	
		forgot-password/page.tsx:48, chat/page.tsx:30,	
		documents/page.tsx:40, documents/[id]/page.tsx:277,	
		settings/page.tsx:19, collections/page.tsx:145,164	

CP-04	Admin/confidential	lib/store.ts:142-153 (canonical),	5
page-level	frontend/lib/permissions.ts		
	permission checks	documents/page.tsx:47, documents/[id]/page.tsx:317,	
instances			
		page.tsx:31-33, search/page.tsx:486	
CP-05	Inline debounce via	documents/page.tsx:89-90, journal/page.tsx:56-60,	
5 instances	frontend/hooks/useDebounce.ts		
	setTimeout	search/page.tsx:710-712,	
		components/SearchModal.tsx:81-83,	
		hooks/useTagSuggestions.ts:55-56	
CP-06	Toast auto-dismiss	collections/[id]/page.tsx, dashboard/page.tsx,	20+
call	frontend/hooks/useToast.ts or		
	(setTimeout(() =>	documents/[id]/page.tsx, documents/page.tsx,	sites
	frontend/lib/toast.ts		
	setToast(null), 5000))	notes/[id]/page.tsx, chat/page.tsx,	
		verify-email/[token]/page.tsx, spaces/[id]/page.tsx	
CP-07	Raw fetch wrappers with	login/page.tsx, register/page.tsx,	30+
raw fetch	frontend/lib/api.ts (expand		
	manual JSON/CSRF	verify-email/[token]/page.tsx,	calls in 12+
existing ApiClient)			
		forgot-password/page.tsx, chat/page.tsx,	files
		documents/[id]/page.tsx, documents/page.tsx,	
		collections/[id]/page.tsx, collections/page.tsx,	

		settings/page.tsx, journal/page.tsx,	
		monitoring/page.tsx	
CP-08	Delete confirmation instances	documents/page.tsx:430, spaces/page.tsx:83, frontend/lib/confirm.ts dialog tasks/[id]/page.tsx:136, tasks/page.tsx:188, subscriptions/page.tsx:271, notes/[id]/page.tsx:112, notes/page.tsx:142, bookmarks/page.tsx:103, collections/page.tsx:181	9
CP-09	Redis lazy singleton + files	openrouter_service.py, search_cache.py, backend/app/core/redis.py close_redis_client() context_block_service.py, api/auth.py, services/monitoring.py, token_blacklist.py, rollback_monitor.py, api/status.py, api/health.py, api/documents_common.py, api/monitoring.py, plus tasks pipeline_orchestrator.py, pipeline_sweeper.py, anomaly_tasks.py, health_report_tasks.py, api/admin.py, api/pipeline_admin.py	14+
CP-10	Cache Prometheus	search_cache.py:58-66, backend/app/utils/cache_metrics.	6+ inline

		metrics recording	semantic_cache.py:148-155,158-165,	blocks
	py		openrouter_service.py:473-510	
	CP-11	LLM message truncation	openrouter_service.py:221-247,	4
services		backend/app/services/llm_common/		
			together_service.py:57-83, kimi_service.py:67-94,	
truncate.py			minimax_service.py:45-70	
	CP-12	LLM token-estimation	openrouter_service.py:215-219,	4
services		Remove wrapper; use		
		wrapper	together_service.py:51-55, kimi_service.py:61-65,	
		token_utils.estimate_tokens from		
			minimax_service.py:40-43	base
class				
	CP-13	OpenAI-compatible SSE	openrouter_service.py:575-589,	4
services		backend/app/utils/sse_parser.py		
		parser	together_service.py:156-170, kimi_service.py:170-185,	
			minimax_service.py:153-168	
	CP-14	LLM health-check	openrouter_service.py:759-801,	5
services		backend/app/services/llm_common/		
		boilerplate	together_service.py:210-252, kimi_service.py:230-269,	
health.py			minimax_service.py:226-250, ollama_service.py:160-201	

		services/document_orchestrator.py:231,	
		services/smart_folder/skills/general_narrative.py:116,	
		services/agents/researcher_agent.py:131	
CP-19	datetime.utcnow()	openrouter_service.py, together_service.py,	30+
call	backend/app/utils/datetime.py		
	timestamps	kimi_service.py, smart_folder_service.py,	sites
across			
		collection_service.py, api/admin.py,	15+ files
		tasks/document_tasks.py, tasks/report_tasks.py, etc.	
CP-20	MIME-type / extension	context_block_service.py:277-295,	4
files	backend/app/utils/mime_map.py		
	mapping	document_orchestrator.py:57-66,	
		api/documents_common.py:144-150,	
		collection_service.py:570-575	
CP-21	React state/form	Most page files keep 5–10 useState variables inline	
~25+ page	Introduce form-state hooks or		
	boilerplate	(e.g., tasks/page.tsx:81-88, documents/page.tsx:52-73)	files
	reusable form components		

Architectural Inconsistencies Observed

Inconsistency	Evidence	Impact
API client schizophrenia Auth refresh, CSRF, base URL, error handling fixed in one place	frontend/lib/api.ts provides full ApiClient, yet many pages reimplement raw fetch with manual CSRF/JSON. do not propagate.	
State management mostly local	Zustand used for auth/chat/upload/search-cache; page forms keep No reusable form state; repeated many inline useState variables.	boilerplate.
No validation library Inconsistent UX; no central schema.	HTML required, manual .trim(), custom validateEmail in forgot-password/page.tsx:21.	
Multiple HTTP abstractions on backend	LLMHTTPClient, ResilientAsyncClient, ad-hoc httpx.AsyncClient. Connection pools, timeouts, retries differ by caller.	

Retry is provider-specific	OpenRouter/Kimi/Ollama use tenacity; Together/MiniMax have none;	
	Some providers silently fail; others retry	
	network_utils has manual loop.	differently.
LLM services ignore SSE	BaseLLMService exists but each provider copies truncation,	
Abstraction ineffective; changes require		
BaseLLMService	parsing, health checks.	4–5 files.
Caching is siloed	Search cache, semantic cache, OpenRouter cache, context-block	
Duplicate connection logic; inconsistent		
	cache each own Redis client and metrics.	TTL/key conventions.
Datetime handling	datetime.utcnow() everywhere; context_block_service.py uses	
Subtle timezone bugs; hard to change format		
	datetime.now(UTC).	globally.

Proposed Shared-Utility Folder Structure

Frontend

...

frontend/lib/

- |— api.ts # expand to cover all raw fetch callers
- |— env.ts # single API_BASE export
- |— formatDate.ts # existing; migrate all callers

```
|— formatFileSize.ts # new
|— permissions.ts    # new: isAdmin, canAccessConfidential
|— confirm.ts        # new: confirmDelete helper
|— toast.ts          # new: auto-dismiss toast state
|— hooks/
|   |— useDebounce.ts
|   |— useApi.ts      # generic fetch + loading/error state
|   |— useToast.ts
...

```

Backend

```
...

backend/app/core/
|— redis.py          # singleton Redis client + close
|— http_client.py    # single async httpx client + retry policy

backend/app/utils/
|— cache_metrics.py  # record_cache_hit / record_cache_miss
|— datetime.py       # utc_now_iso, utc_now_filename_ts
|— permissions.py    # is_admin_or_superuser, can_access_confidential
|— mime_map.py       # extension <-> mime + short labels
|— sse_parser.py     # OpenAI-compatible streaming parser

backend/app/services/llm_common/
|— truncate.py
|— config.py
|— health.py
...

```

Error Handling Maturity Matrix

Area	Current State	Gold Standard	
Gap			
Severity			

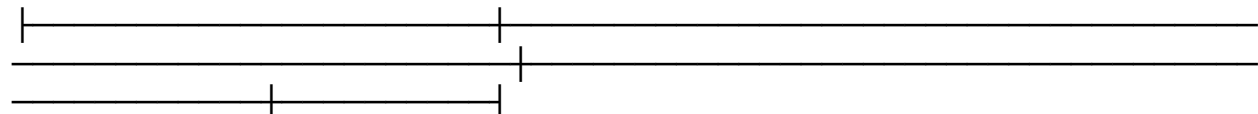
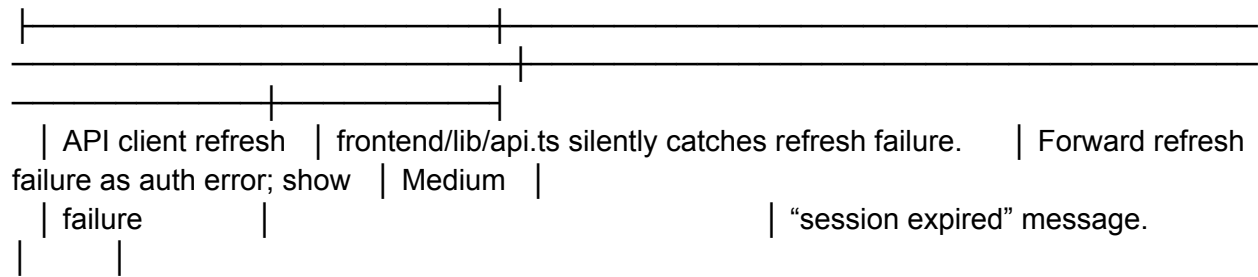
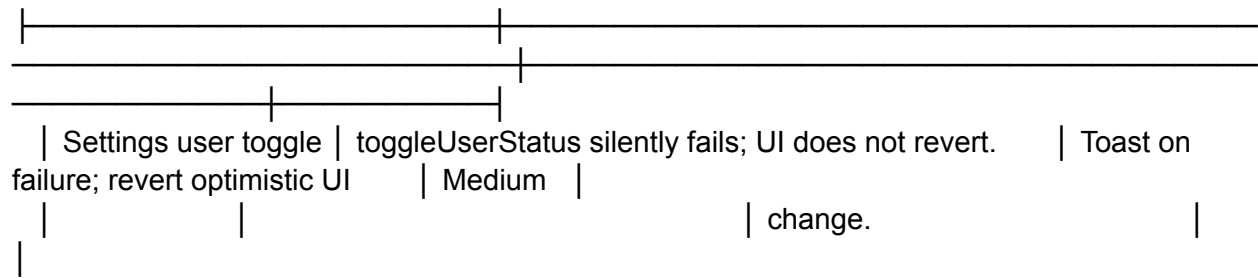
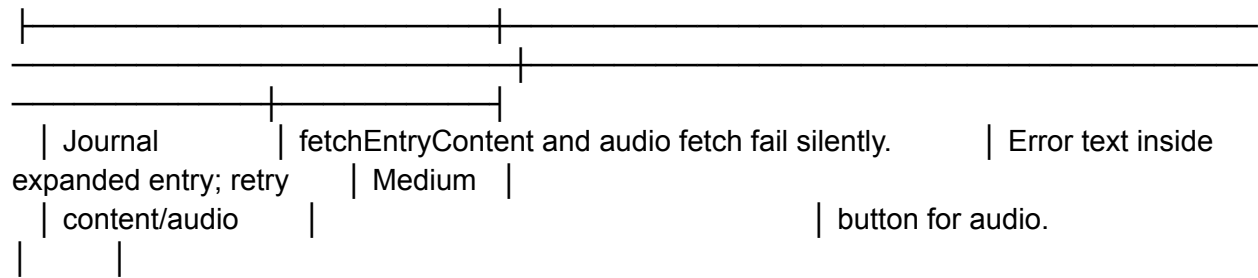
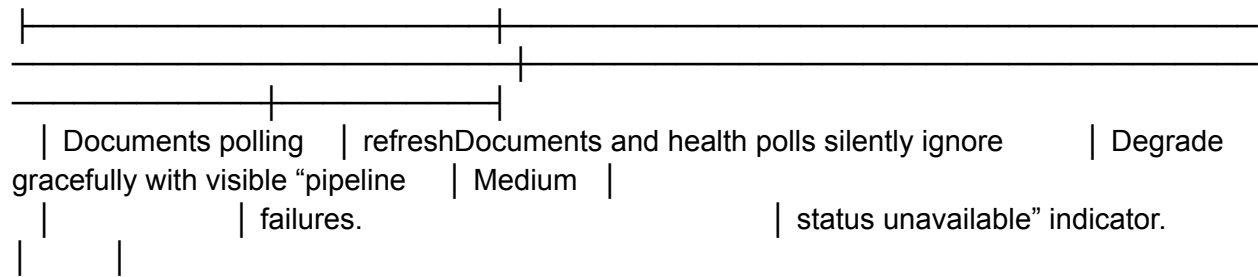
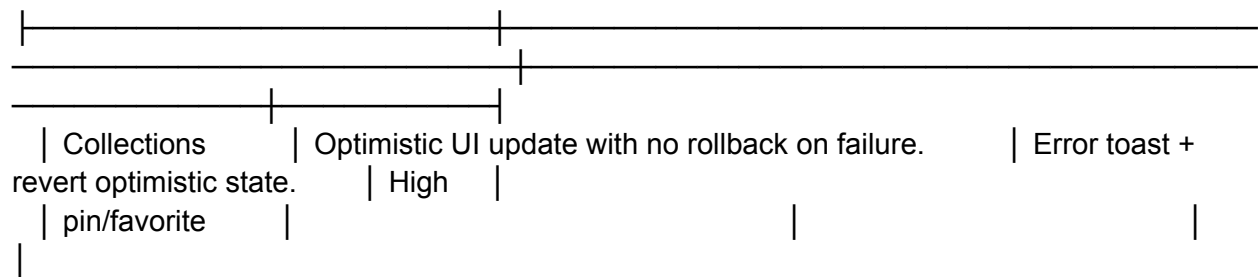
Global React Error frontend/app/error.tsx + Boundary top-level	None. No error.tsx found anywhere under frontend/. Critical	Root frontend/app/[locale]/error.tsx + Error Boundary around client shell.
---	--	--

Global API error Centralized error state + toast; user-visible feedback	Most pages catch errors with console.error only. No global Critical toast/snackbar.	message for every failed mutation.
---	---	---------------------------------------

Chat error handling field; render inline error; clear	frontend/lib/store.ts swallows createSession, Critical loadSessions, loadMessages, sendMessage errors.	Store error on success.
--	--	----------------------------

Dashboard live stats Non-blocking error banner or stale-data logs only.	frontend/app/[locale]/dashboard/page.tsx loadLiveStats High indicator.	
---	--	--

Notes / Bookmarks / Tasks / Spaces mutations	All handleSave/handleDelete/fetchX catch and only High console.error.	Inline error banner for fetch; toast for mutations.
--	---	---



| Native alert() usage | settings/page.tsx password reset, subscriptions/page.tsx |
Non-blocking toast or modal; | Medium |
| | test reminder, collections/page.tsx delete use alert(). | copy-to-clipboard
for generated passwords. | |

| | |
| | |
| Loading states | Spinners present for initial load, but empty/error states | Skeleton
screens + dedicated error | Medium |
| | are often missing. | placeholder with retry.
| |

Request cancellation	Most useEffect fetches have no AbortController; chat
AbortController per effect; cancel stale	High
/ race conditions	streaming cannot be stopped.
button for streaming. | |

| | |
| | |
| Backend global | backend/app/main.py:279-316 registers handlers for |  Meets
gold standard for API envelope. | — |
| exception handling | validation, DB, and catch-all Exception. |
| |

Backend transaction	backend/app/middleware/transaction.py:25-43 rolls back and
Re-raise is correct; should also	Low
middleware	re-raises.
re-raise. | |

| | |
| | |
| Backend fail-open | search_agent_router.py defaults to PUBLIC bucket on any | Fail
secure/closed; explicit validation; log | High |
| paths | exception; input_guard.py treats PII scan failure as safe; | and surface
errors. | |

		pipeline_orchestrator.py swallows status-check failures.	
	Backend audit	backend/app/api/admin.py:1233-1244,1340-1355 silently pass	Log at logger.exception; optionally fail-safe
	logging	on audit-log failures.	High in high-security mode.

Critical File-Level Gaps

#	File	Lines / Function	Current Failure		
Unprotected Endpoint / UI				Mode	
ERR-01	frontend/app/layout.tsx / Every page/component	entire files	No error.tsx		
	frontend/app/[locale]/layout.tsx				
ERR-02	frontend/lib/store.ts console.error	createSession 223–242, loadSessions /v1/chat/sessions, 244–255, loadMessages 257–271, /v1/chat/sessions/{id}/messages, sendMessage 273–346 message	only streaming		

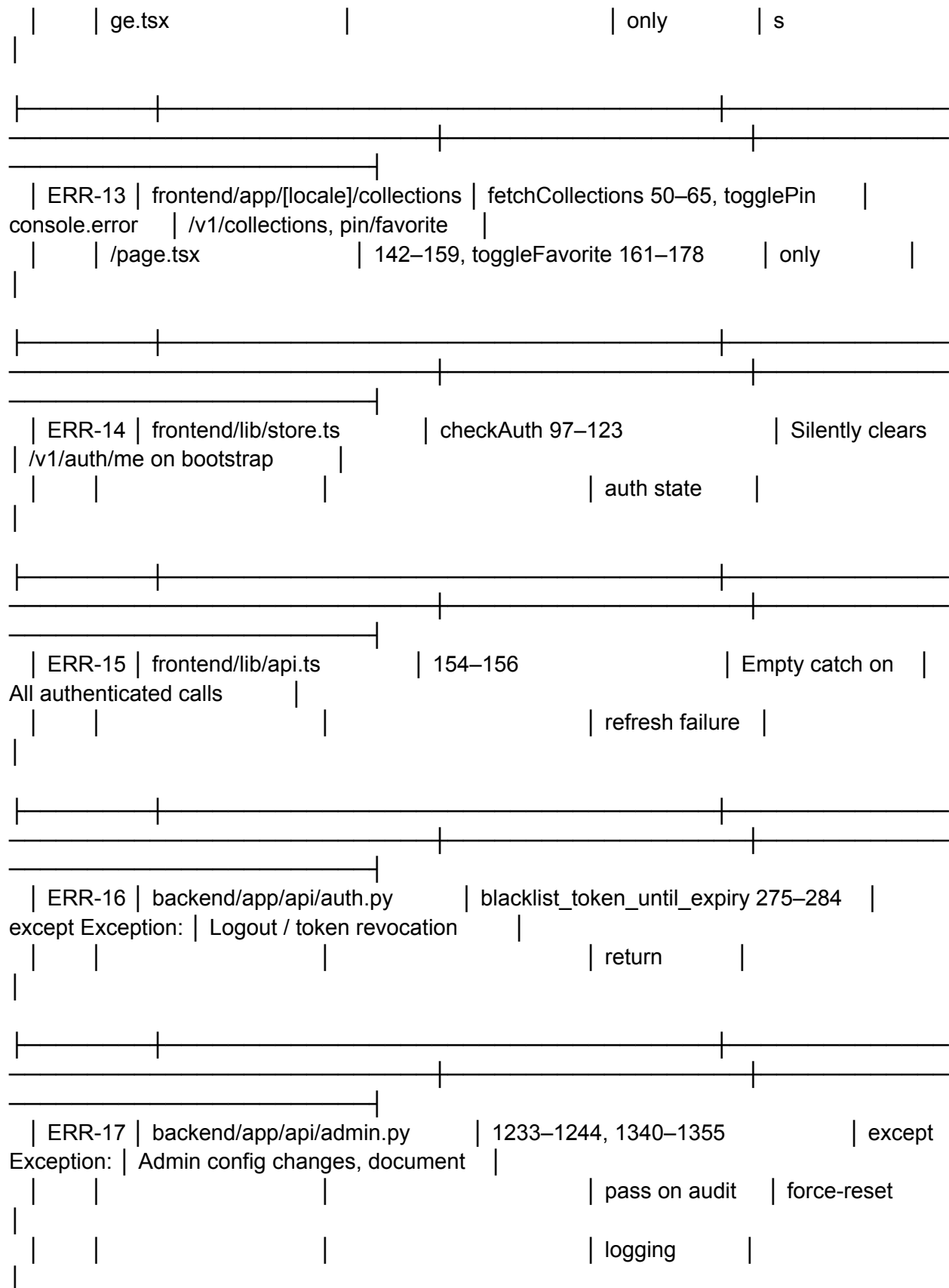
```

graph LR
    ERR-03[ERR-03] --- console.error[console.error]
    console.error --- age.tsx[age.tsx]
    age.tsx --- Admin[Admin dashboard live tiles]
    Admin --- loadLiveStats[loadLiveStats]
    loadLiveStats --- only[only]
    only --- 179-216[179-216]
  
```

Timeline diagram showing the development of the application. The timeline is divided into two main sections: 'ERR-04' and 'fetchNotes 63-80, handleSave 111-139, console.error /v1/notes CRUD'. The 'ERR-04' section includes 'tsx' and 'handleDelete 141-150'. The 'fetchNotes' section includes 'only'.

ERR-05	frontend/app/[locale]/spaces/[id]	fetchSpace 70–83, handleSync 87–98,
console.error	/v1/spaces/{id} operations	
	/page.tsx	handleRemoveItem 100–108, handleAddRule
		only
		110–121, handleToggleRule 123–131,
		handleDeleteRule 133–141

File	Line	Code
ERR-06 frontend/app/[locale]/chat/page.t	75–90,	loadSessions
console.error Chat session sidebar	92–105,	createSession
sx	107–128,	only;
		deleteSession
	130–149	loadMessages
		error not cleared
		on success



File	Line Range	Function	Notes
backend/app/tasks/pipeline_orchestrator.py	248–267, 278–289, 294–308	Document pipeline dispatch	
backend/app/tasks/pipeline_orchestrator.py	status-check		
backend/app/tasks/pipeline_orchestrator.py	failures		
backend/app/api/search_agent_router.py	63–66	/api/v1/search/agent	Defaults to PUBLIC bucket on any exception
backend/app/services/input_guard.py	180–186	All queries via InputGuard.process	Treats PII failure as safe

Actionable Remediation Playbook

Goal: Remove critical/high vulnerabilities before any other work.

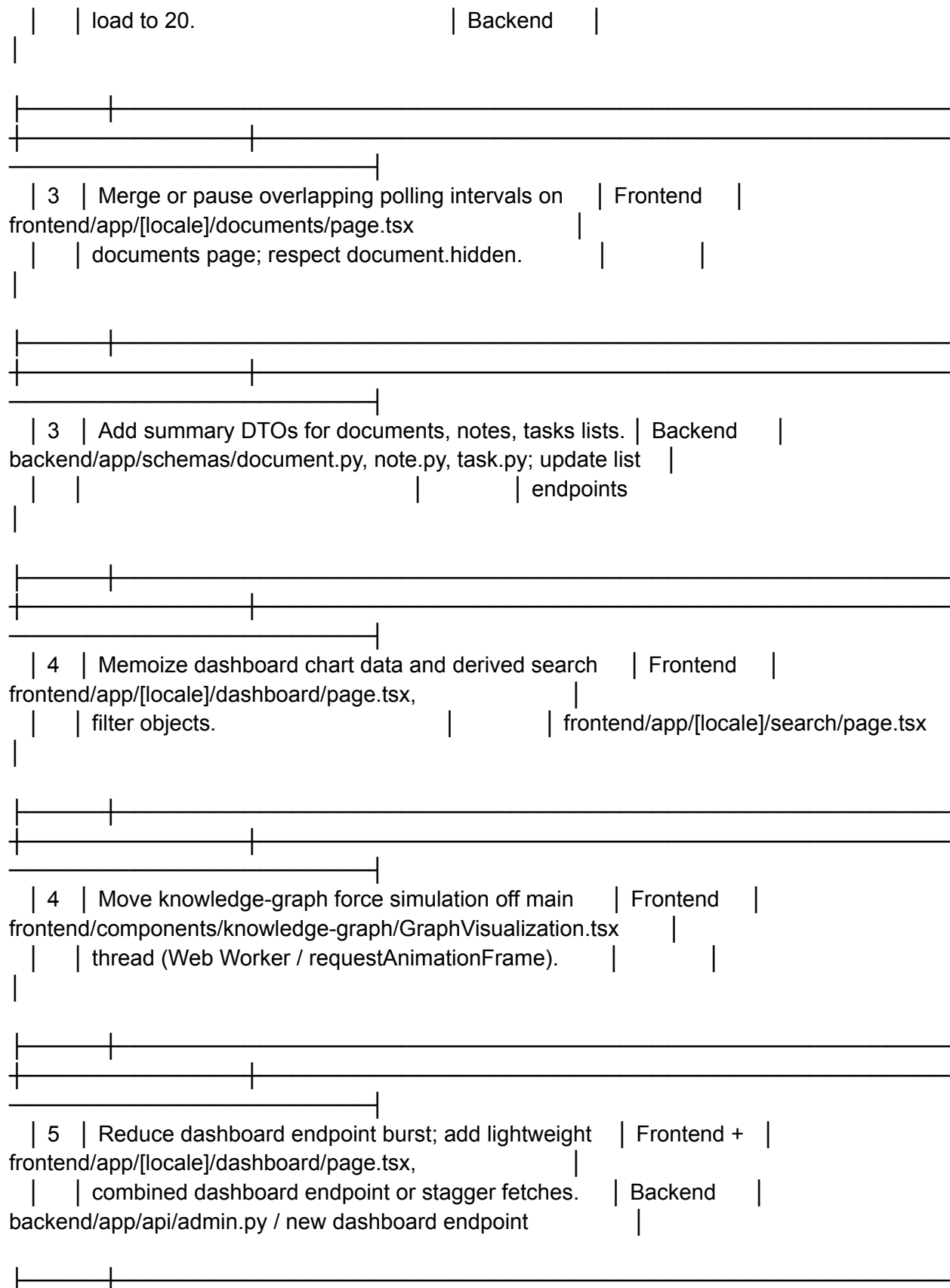
Day	Task	Owner	Files to Change
1	Remove JWT_SECRET from frontend Docker build/runtime; frontend/Dockerfile, frontend/Dockerfile.dev, verify middleware does not need it.	Backend + DevOps	docker-compose.yml, docker-compose.production.yml
1	Remove default Admin123! fallback in deploy script; fail loudly if ADMIN_PASSWORD is unset.	DevOps	
2	Remove or require explicit rotation of default admin row in DB init script.	Backend	
2	Remove direct backend host port mapping; route all traffic through nginx.	DevOps	
3	Fix rate-limiting to use X-Forwarded-For behind nginx; backend/app/limiter.py, backend/app/main.py, nginx config	Backend	

		add ProxyHeadersMiddleware.		
	3	Enforce email_verified at login or remove unused verification flow.	Backend	
		backend/app/api/auth.py		
	4	Fix registration message to generic "Invalid credentials" / prevent email enumeration.	Backend	
		backend/app/api/auth.py		
	4	Make Telegram auth verify Telegram identity unconditionally or fail closed.	Backend	
		backend/app/api/auth.py		
	5	Add __Host- prefix to auth cookies; pin COOKIE_DOMAIN to exact host in production.	Backend	
		backend/app/api/auth.py, env templates		
	5	Security smoke tests + rotate all credentials referenced in README exposure table.	DevOps	.env files,
		GitHub/Moonshot/Telegram admin panels		

Week 2 — Performance Quick-Wins

Goal: Reduce main-thread jank, backend load, and request waste.

Day	Task	Owner	Files to Change
1	Add useDebounce hook and apply to notes, tasks, entity-list search inputs.	Frontend	frontend/hooks/useDebounce.ts, notes/page.tsx, tasks/page.tsx, components/knowledge-graph/EntityList.tsx
1	Memoize ReactMarkdown components map and chat message items.	Frontend	frontend/app/[locale]/chat/page.tsx
2	Create chat message-list summary DTO; omit chunk_text and token fields.	Backend	backend/app/schemas/chat.py, backend/app/api/chat.py
2	Add cursor pagination to chat messages; cap initial	Frontend + Backend	frontend/app/[locale]/chat/page.tsx, backend/app/api/chat.py



5	Remove inline style objects and arrays in page.tsx, frontend/app/[locale]/page.tsx, frontend/app/layout.tsx, layout.tsx, SearchModal.tsx.	Frontend	frontend/app/[locale]/layout.tsx, frontend/components/SearchModal.tsx

Week 3 — Code Refactoring & Error Boundaries

Goal: Eliminate duplication and make the frontend resilient.

Day	Task	Owner	Files to Change
1	Add root and locale error.tsx; wrap client frontend/app/[locale]/error.tsx, shell in React Error Boundary.	Frontend	frontend/app/error.tsx, frontend/app/[locale]/layout.tsx
1	Introduce global toast/snackbar and replace settings/page.tsx, subscriptions/page.tsx, all alert() calls.	Frontend	frontend/lib/toast.ts, collections/page.tsx

2	Build useApi hook with loading/error/abort	Frontend	frontend/hooks/useApi.ts, login/page.tsx, register/page.tsx,
	support; migrate raw fetch callers.		chat/page.tsx,
documents/[id]/page.tsx, collections/page.tsx,			settings/page.tsx, etc.

2	Add AbortController cleanup to all useEffect	Frontend	All data-fetching pages, frontend/app/[locale]/chat/page.tsx
	data fetches; implement chat "Stop" button.		

3	Centralize frontend permissions, date	Frontend	frontend/lib/permissions.ts, frontend/lib/formatFileSize.ts,
	formatting, file-size formatting,		frontend/lib/confirm.ts; migrate callers
	confirmations.		

3	Centralize backend Redis client in	Backend	backend/app/core/redis.py; update 14+ files
	backend/app/core/redis.py; migrate all		
	callers.		

4	Refactor LLM providers to shared truncation,	Backend	backend/app/services/llm_common/, openrouter_service.py,
	SSE parser, health check, config helpers.		together_service.py, kimi_service.py, minimax_service.py

4	Centralize backend permissions and datetime utilities; fail-open paths fail closed.	Backend	
	backend/app/utils/permissions.py, backend/app/utils/datetime.py; fix input_guard.py, pipeline_orchestrator.py,		search_agent_router.py,
			admin.py audit logging
5	Add per-page error placeholders with retry actions; backend should log audit failures.	Frontend + Backend	All list pages,
	backend/app/api/admin.py, backend/app/middleware/transaction.py		

Definition of Done (per week)

- Week 1: Security issues SEC-01–SEC-08 closed; deployment no longer exposes backend directly; no default passwords.
- Week 2: Chat jank < 100 ms on 50-message histories; debounced search inputs; dashboard initial calls ≤ 3 .
- Week 3: Zero alert() calls; raw fetch migrated to api.ts for auth flows; root error.tsx present; backend fail-open paths replaced with explicit validation.

Notes on Scope & Methodology

- This audit relied only on source code under the working directory; prior audit reports in `audit_reports/` and `docs/` were not used as evidence.
- Severity ratings are relative to production impact, not theoretical CVSS scores.
- Line numbers reference the current state of the repository; refactor work will shift them.
- Where duplicate-instance counts overlap (e.g., raw fetch wrappers often repeat `API_BASE`), each distinct file/occurrence was counted once.